

Facilitator answer key — Holocron capstone worked solution.

Facilitator-only — lives in the facilitator folder of every repo; do not hand to participants. Part of the internally-consistent set in this folder (see `README.md`).

TCD-light — Holocron (release-1 slice)

Scale: 150+ countries, 20–30+ consuming apps, 30–40 locales, en-US source, ~500k strings, Internal data. Slice: access roles, product setup, create/edit/publish, version history + audit, search, delivery, review, translation variants (CS1–7, CS11–12, CS15). Out: aliases, advanced reviewer config, export/import, rollback, AI translation, Figma.

1. Architecture stance

A **modular service on AKS** — one deployable, internally separated modules; not a microservice mesh, not an unscalable monolith. The decisive move: **two physically separate paths over one PostgreSQL system of record** — a low-traffic **authoring path** (create/edit/publish/review; management app 99.5%) and a high-traffic, read-optimized **delivery path** fronted by **Azure Cache for Redis** and served through **API Management + Application Gateway** (delivery 99.9%, p95 ≤200ms). Rationale: 20–30+ apps fetching on every render generate far more traffic than a handful of editors; collapsing both paths would let read spikes starve publishing. Publish + audit-write stay in one transaction; a service is extracted only when a module's scale or ownership demands it.

2. Integration map

System	Sync/Async	R/W	Failure handling
Azure Database for PostgreSQL (system of record)	Sync	R/W	Publish + audit in one tx; failover to replica.
Azure Cache for Redis (delivery cache)	Sync read / async fill	R/W-on-publish	Miss → read-through + backfill; down → direct Postgres reads (SLO-protected by rate limit).
Microsoft Entra ID (identity)	Sync	R	Token validated every call; token-endpoint outage → cached JWKS validates, new sign-ins blocked (fail-closed).
App Gateway + API Management (delivery edge)	Sync	R	TLS, per-consumer rate limit (50 req/s, burst 100), token validation; backend down → 503 + Retry-After.

System	Sync/Async	R/W	Failure handling
Event Hubs → Blob (audit)	Async	W	Every mutating op emits an AuditEntry → WORM archive; hub down → buffer + retry, publish still commits.
Key Vault (secrets)	Cached	R	DB creds, cache keys, signing; vault down → last-cached secrets, block rotation, alert.
Azure Monitor (observability)	Async	W	Metrics/logs/alerts; telemetry loss is non-blocking.

3. Threat model (STRIDE)

Threat	Mitigation
Spooing a consumer	Entra ID token validation at the APIM edge; per-app scoped audiences; no anonymous delivery.
Tampering with content	TLS end to end; Postgres is the only write path (delivery read-only); RBAC-gated publish.
Repudiation of publish/approve	Immutable AuditEntry per op → Event Hubs → Blob; actor from token; override itself audited.
Elevation via role scope	Entra ID roles enforced server-side per operation; product-scoped; least-privilege delivery identity.
Denial of service on delivery	Per-consumer 50 req/s / burst 100 at APIM; Redis absorbs load; delivery scales independently.

4. SLOs

SLO	Target
Delivery fetch latency	p95 ≤ 200ms / p99 ≤ 500ms
Delivery availability	99.9% (management app 99.5%)
Publish → delivery propagation	≤ 60s normal / < 5s for critical/legal -flagged strings (synchronous invalidation, per SEP §3)
Per-consumer rate limit	50 req/s, burst 100

Verify via Azure Monitor percentile dashboards + a publish-to-fetch timing probe, split by flag.

5. Top 3 trade-offs

Choice	Accepted cost	Revisit trigger
Redis read-cache (vs strong-consistency Postgres reads)	≤60s staleness for normal strings; critical/legal get synchronous <5s invalidation (SEP §3)	An <i>unflagged</i> string class needs <5s across the board.
Reviews optional + audited override (vs mandatory gates)	A <i>normal</i> string can ship unreviewed (audit, not prevention); critical/legal require enforced pre-publish review (SEP §3)	Compliance extends enforced approval beyond the flagged class.

Choice	Accepted cost	Revisit trigger
Immutable namespaced keys (vs renamable)	Renaming = create-new + deprecate-old	In-place renames become unmanageable at scale.

6. Stakeholder sign-off

Stakeholder	Status
Product lead (Holocron)	Approved
Platform / SRE lead — AKS, SLOs, Redis/Postgres split	Approved
Security / Identity lead — Entra ID, RBAC, audit immutability	Approved (pending Key Vault rotation runbook)
Consuming-app representative — delivery contract + ≤60s tolerance	Approved
Legal / Compliance (governance owner)	Approved — <code>critical/legal</code> flag enforces pre-publish review + <5s propagation (SEP §3)